



INTERNSPARK

VULNERABILITY ASSESSMENT REPORT

Security assessment identifying exposed services, misconfigurations, vulnerability risks, and recommended remediation measures through Nmap and Nikto scanning.

MAY 2026

VIBHOR GUPTA

Approved by
internSpark

Introduction:

Objective:

The objective of this assessment was to perform active reconnaissance and vulnerability scanning on a safe test environment in order to identify exposed services, potential security weaknesses, and configuration-related risks.

Scope:

The assessment focused on:

- Port and service enumeration using Nmap
- Web vulnerability scanning using Nikto
- Identification of exposed services, insecure configurations, and informational disclosures

Tools Used:

- Nmap — Used for identifying open ports, running services, and network exposure on the target system.
- Nikto — Used for detecting web server misconfigurations, exposed directories, insecure headers, and potential vulnerabilities.

Methodology:

The assessment was conducted in two phases:

Phase 1 — Reconnaissance and Port Enumeration:

The target host was scanned using Nmap to identify:

- Open ports
- Running services
- Service exposure levels
- Network accessibility

Phase 2 — Web Vulnerability Scanning:

Nikto was used to analyze the web application and identify:

- Misconfigurations
- Exposed directories
- Insecure HTTP methods
- Informational disclosures
- Weak security policies

Nmap Scan Results:

Scan Overview:

The target system was scanned using Nmap to identify open ports, running services, and potential network exposure. The scan successfully detected active services running on multiple ports.

Open Ports Identified:

Port	Service	Status	Risk Level
3000	HTTP/Web Application	Open	Medium
135	RPC Service	Open	Medium
445	SMB Service	Open	High

Key Observations:

- The web application was accessible through port 3000.
- RPC services were exposed on port 135.
- SMB services were exposed on port 445.
- Additional open ports indicated system-level exposure beyond the web application scope.

Security Concerns Identified:

- Publicly accessible services increase attack surface exposure.
- SMB services are frequently targeted in ransomware and unauthorized access attacks.
- Exposed RPC services may allow system enumeration and remote communication attempts.

Nmap Scan Findings:

Finding 1: Web Application Exposure (Port 3000):

Risk Level:

Medium

Description:

The web application was accessible on port 3000 and responded successfully to HTTP requests.

Evidence:

- HTTP response detected
- Status code: 200 OK

Security Risk:

Exposed application ports increase the risk of:

- Unauthorized access attempts
- Automated scanning
- Exploitation of application vulnerabilities

Remediation:

- Restrict external access using firewall rules
- Deploy the application behind a reverse proxy
- Allow access only from trusted networks

Finding 2: Unrecognized Service on Port 3000:

Risk Level:

Low

Description:

The service running on port 3000 could not be fully identified by the scanner.

Security Risk:

Non-standard or unidentified services may complicate:

- Security monitoring
- Service management
- Incident response

Remediation:

- Maintain proper service documentation
- Monitor exposed services regularly
- Use standardized configurations where possible

Finding 3: SMB Service Exposure (Port 445):

Risk Level:

High

Description:

Port 445 was found open on the host system, indicating SMB service exposure.

Security Risk:

SMB services are frequently targeted for:

- Unauthorized file access
- Remote exploitation
- Malware and ransomware attacks
- Lateral movement within networks

Note:

This exposure originates from the host operating system rather than the web application.

Remediation:

- Disable SMB if unnecessary
- Restrict SMB access using firewall rules
- Permit access only from trusted internal systems

Finding 4: RPC Service Exposure (Port 135):

Risk Level:

Medium

Description:

RPC services were detected on port 135.

Security Risk:

Improperly secured RPC services may allow:

- Service enumeration
- Remote attacks
- Unauthorized system communication

Note:

This service belongs to the host operating system and not the web application itself.

Remediation:

- Restrict external access
- Allow access only from trusted networks
- Disable unnecessary RPC-related services

Nikto Scan Results:

Scan Overview:

The web application was scanned using Nikto to identify web server misconfigurations, insecure headers, exposed directories, and other potential security weaknesses.

Vulnerabilities Identified:

Finding	Risk Level
Information Disclosure via ETags	Low
Overly Permissive CORS Policy	Medium
Exposure of Hidden Directories	Medium
Informational Headers Disclosure	Low
Broad HTTP Methods Allowed	Medium
Accessible Hidden Directories	Medium

Key Observations:

- The server leaked inode information through ETag headers.
- Cross-origin requests were allowed from all origins using wildcard CORS configuration.
- Sensitive directories such as “/ftp/” and “/public/” were accessible.
- Multiple HTTP methods including PUT, DELETE, and PATCH were enabled.
- Informational headers revealed internal application details.

Security Concerns Identified:

- Misconfigured CORS policies may expose sensitive resources.
- Public directories can reveal confidential files or application resources.
- Excessive HTTP methods increase the attack surface.
- Informational disclosures assist attackers during reconnaissance activities.

Nikto Scan Findings:

Finding 1: Information Disclosure via ETags:

Risk Level:

Low

Description:

The server leaks inode-related metadata through ETag headers.

Evidence:

- Server leaks inodes via ETags

Security Risk:

This information may assist attackers in server fingerprinting and reconnaissance activities.

Remediation:

- Disable ETags if not required
- Remove inode information from server responses

Finding 2: Overly Permissive CORS Policy:

Risk Level:

Medium

Description:

The application uses:

“Access-Control-Allow-Origin: *”

which allows any external domain to access application resources.

Security Risk:

This may expose sensitive data to malicious third-party websites.

Remediation:

- Restrict allowed origins to trusted domains only
- Avoid wildcard CORS policies in production

Finding 3: Exposure of Hidden Directories via robots.txt:

Risk Level:

Medium

Description:

The robots.txt file revealed hidden application directories.

Evidence:

- /ftp/ returned HTTP 200

Security Risk:

Attackers may use exposed paths for reconnaissance and unauthorized access attempts.

Remediation:

- Avoid exposing sensitive paths in robots.txt
- Restrict access to internal directories

Finding 4: Informational HTTP Headers:

Risk Level:

Low

Description:

The server exposes informational headers such as:

“x-recruiting: /#/jobs
feature-policy”

Security Risk:

These headers may reveal internal application structure and development information.

Remediation:

- Remove unnecessary headers
- Limit exposure of internal details

Finding 5: Broad HTTP Methods Allowed:

Risk Level:

Medium

Description:

The server allows multiple HTTP methods:

“GET, POST, PUT, DELETE, PATCH“

Security Risk:

Unused HTTP methods increase the application's attack surface.

Remediation:

- Disable unnecessary HTTP methods
- Restrict server functionality to required operations only

Finding 5: Broad HTTP Methods Allowed:

Risk Level:

Medium

Description:

The following directories were publicly accessible:

- /ftp/
- /public/

Evidence:

- OSVDB-3092: /ftp/: This might be interesting
- OSVDB-3092: /public/: This might be interesting

Security Risk:

Accessible directories may expose:

- Sensitive files
- Internal resources
- Backup data
- Misconfigured content

Remediation:

- Restrict public directory access
- Disable directory listing
- Remove unnecessary public resources

Overall Risk Assessment:

The assessment identified several security weaknesses related to:

- Service exposure
- Misconfigured security policies
- Informational disclosures
- Excessive HTTP methods
- Exposed directories

The most significant issue identified was the exposure of SMB services on port 445,

The combination of:

- Open system ports
- Exposed directories
- Broad HTTP methods
- Permissive CORS policies

increases the overall attack surface of the host system's and may allow unauthorized access or exploitation attempts.

Additional open ports (135 and 445) indicate system-level exposure beyond the web application scope.

No critical web application vulnerabilities were identified during the scan; however, applying the recommended remediations would significantly improve the security posture of the environment.

Overall Recommendations and Remediation:

1. Restrict Unnecessary Open Ports

- Close unused ports such as 135 and 445 if not required.
- Use firewall rules to limit access to trusted systems only.
- Monitor exposed services regularly.

2. Secure SMB and RPC Services

- Disable SMB services where unnecessary.
- Restrict SMB and RPC communication to internal trusted networks.
- Keep the operating system updated with the latest security patches.

3. Harden Web Server Configuration

- Disable unnecessary HTTP methods such as PUT, DELETE, and PATCH.
- Remove unnecessary informational headers.
- Configure secure and consistent server settings.

4. Restrict Directory Exposure

- Remove public access to sensitive directories like /ftp/ and /public/.
- Disable directory listing functionality.
- Avoid exposing sensitive paths in the robots.txt file.

5. Improve CORS Security

- Replace wildcard CORS configuration with trusted domain-specific origins.
- Apply strict cross-origin access policies.

6. Prevent Information Disclosure

- Disable inode leakage through ETag headers.
- Minimize exposure of internal server and application details.

Conclusion:

The vulnerability assessment successfully identified multiple medium- and low-risk security issues within the target environment. The findings primarily involve insecure configurations, exposed services, and unnecessary information disclosure.

Implementing the recommended mitigation measures would reduce attack surface exposure, strengthen system security, and improve overall resilience against common reconnaissance and exploitation attempts.

Appendix:

Tools Used:

- Nmap
- Nikto

Screenshots:

```
latest: Pulling from frapsoft/nikto
17693e7a6d88: Pull complete
c5ef6b33992: Pull complete
Digest: sha256:e2206e3a1d4950d363fb542e405664937c6db2a4fe4e97ee73dc34dcde00ad89
Status: Downloaded newer image for frapsoft/nikto:latest
- Nikto v2.1.5

+ Target IP: 192.168.65.254
+ Target Hostname: host.docker.internal
+ Target Port: 3000
+ Start Time: 2026-05-02 13:08:33 (GMT0)

+ Server: No banner retrieved
+ Server leaks inodes via ELangs, header found with file /, fields: 0xW/124fa 0x19de8c9b268
+ Uncommon header 'x-frame-options' found, with contents: SAMEORIGIN
+ Uncommon header 'access-control-allow-origin' found, with contents: *
+ Uncommon header 'x-recruiting' found, with contents: /#/jobs
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'feature-policy' found, with contents: payment 'self'
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ File/dir '/ftp/' in robots.txt returned a non-forbidden or redirect HTTP code (200)
+ 'robots.txt' contains 1 entry which should be manually viewed.
+ Uncommon header 'access-control-allow-methods' found, with contents: GET,HEAD,PUT,PATCH,POST,DELETE
+ OSVDB-3892: /ftp/: This might be interesting...
+ OSVDB-3892: /public/: This might be interesting...
+ 6544 items checked: 2 error(s) and 11 item(s) reported on remote host
+ End Time: 2026-05-02 13:13:06 (GMT0) (273 seconds)

+ 1 host(s) tested
```

nikto scan

```
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00662s latency).
Other addresses for localhost (not scanned):::1
Not shown: 997 closed tcp ports (reset)
```

	PORT	STATE	SERVICE	VERSION
135/tcp	open	nmapro	Microsoft Windows RPC	
445/tcp	open	microsoft-sd?		
3000/tcp	open	pppt?		

```
l service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?f=serviceprint:
_._Port:3000-TCP.W:7.99%I=74M;S/2+Time=6PFSF6BFP#i686-pc-windows-windowssr
SF:(GetRequest,IC&,HTTP/1\.\.xk20200\x20OK\r\nAccess-Control-Allow-Origin
SF:\x20*\r\nX-Content-Type-Options:\x20nosniFF\r\nX-FRAME-OPTIONS:\x20SA
SF:#MSOBLIGIN\r\nFeature-Policy:\x20payment\x20self'\r\nRecruiting:\x20/#
SF:/jobs/rAccess-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-ag
SF:\r\nLast-Modified:\x20Sat,\x20202\x20May\x202026;\x2013:03:45\x20GMT\r
SF:=ETag:\x20W/\x20f4ef4e19debfce9be268"\r\nContent-Type:\x20text/html;\x20ch
SF:laret=UTF-8\r\nContent-Length:\x2075002\r\nVary:\x20Accept-Encoding\r\n
SF>Date:\x20Sat,\x202\x20May\x202026;\x2013:06:07\x20GMT\r\nConnection:\x2
SF:xClose\r\n\r\n<!-\x20\x20-\x20Copyright\x20(\xc)\x202014-2026\x20BJo
SF:\x20Jinminshixunxi\x20Beijing\x20ChinaOMASP\x20Juice\x20Contributors'
SF:.</\x20XML\x20Document-LICENSE-Identifier:\x20MIT\r\n\x20\x20-->>\x20lnkdody
SF:pe>\x20html>\x20<!\x20lang=en">\x20data-beasties-container>\x20head<\x
SF:>\x20\x20meta\x20charset=utf-8">\x20\x20<title>OMASP\x20Juice\x2OS
SF:hop<file>\x20\x20meta\x20name=&"description">\x20content=&'Probabl
SF:yly\x20\x20"\x20order\x20and\x20specified\x20insecure\x20webVx
SF:Application")>\x20\x20\x20meta\x20name=&'viewport">\x20content=""width
SF:=device-width,\x20initial-scale=1"/>\x20\x20link\x20id=favicon">x
SF:_2orel=\x20icon"x20">%&(Hwelp,2F,"HTTP/1\.\.xk20400\x20Bad\x20Request\r\nC
SF:nnection:\x20close\r\n\r\n)>%&(INCP,2F,"HTTP/1\.\.xk20400\x20Bad\x20Requ
SF:est\r\nConnection:\x20close\r\n\r\n)">%&(HTTPOptions,EA,"HTTP/1\.\.xk202
SF:/x20(No)\x20Access-Control-Allow-Origin:">%&(AccessCont
SF:rol-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Acess
SF:-Control-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Sat,\x202
SF:/x20May\x202026;\x2013:06:08\x20GMT\r\nConnection:\x20close\r\n\r\n)">%&(
SF:RTSPrequest,EA,"HTTP/1\.\.xk20204\x20No\x20Access-Control-Allow-Orig
SF:ow-Origin:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCh
SF:,POST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Le
SF:gth:\x200\r\nDate:\x20Sat,\x202\x20May\x202026;\x2013:06:08\x20GMT\r\nCo
SF:nnection:\x20close\r\n\r\n")>
```

Service Info: OS: Windows; CPE: cpe:/microsoft/windows

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 13.72 seconds
```

nmap scan